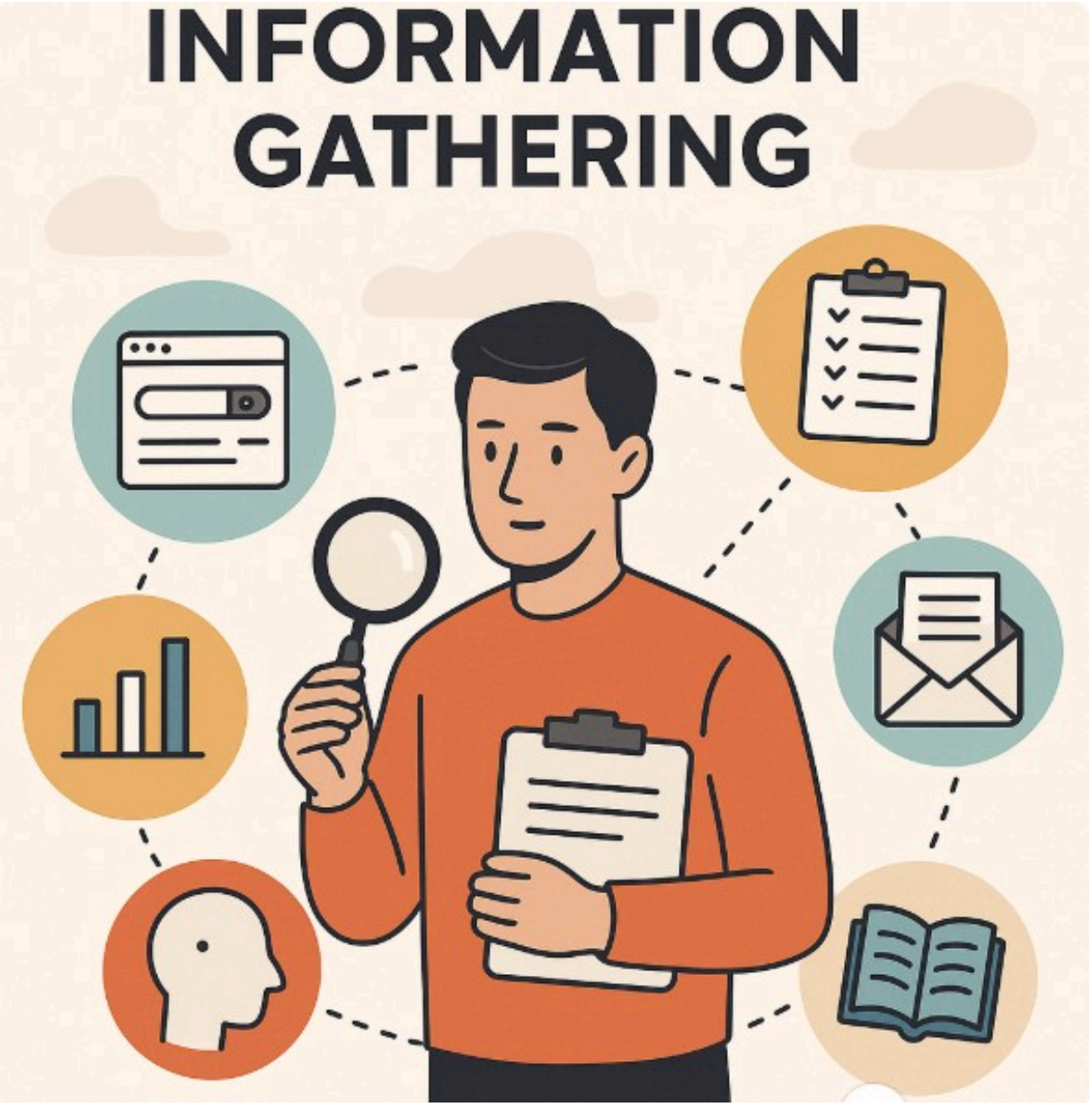
Information Gathering



Introducció **2**
Activitat 2.4 **3**
1. Cerques Google Dorks 3
2. Configuració fitxer Robots.txt 9
Act 2.4.2 **11**
1. Whois 11
2. Dig 12
3. Recon-ng 13
4. Sublist3r 15
5. Spiderfoot 17
6. Exiftool 20
7. Shodan 22
Activitat 2.4.3 **24**
1. Activitats prèvies 24
2. Escenari Fictici 31

Introducció

Aquesta pràctica té com a objectiu comprendre la importància de la recopilació d'informació en ciberseguretat i com les dades públiques d'una organització poden revelar possibles riscos. També es pretén conèixer les tècniques que permeten identificar informació exposada a Internet i entendre la importància de protegir-la adequadament.

A més, s'estudien les diferents tècniques d'enginyeria social, especialment els tipus de phishing que utilitzen els atacants per enganyar les persones i obtenir informació confidencial, com ara contrasenyes o dades bancàries. Mitjançant exemples i situacions pràctiques, es busca aprendre a identificar els senyals d'alerta, reconèixer possibles intents de frau i saber com actuar davant d'aquestes situacions.

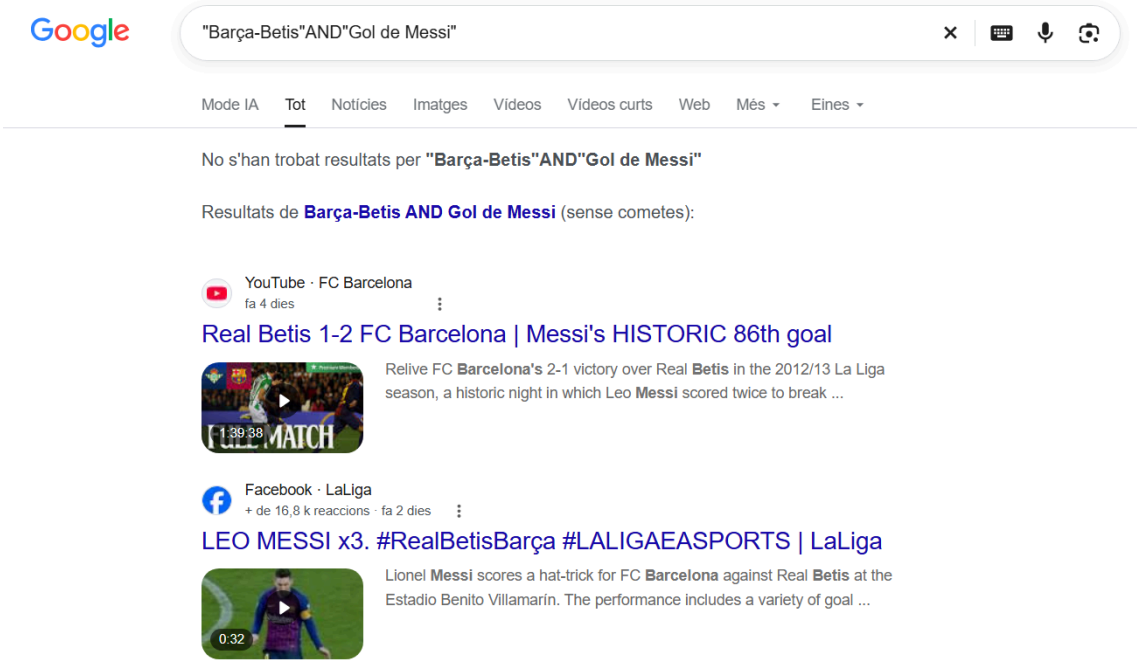
Finalment, es vol destacar que la ciberseguretat no depèn únicament de la protecció dels sistemes informàtics, sinó també de la gestió correcta de la informació i de la conscienciació dels usuaris per prevenir possibles atacs.

Activitat 2.4

1. Cerques Google Dorks

a) Buscar los partidos del barça-Betis con goles de messi

Les cometes s'utilitzen per forçar la cerca de la frase exacta continguda a l'interior i evitar que es cerquin les paraules per separat, mentre que l'operador AND requereix que ambdós termes exactes apareguin simultàniament en el mateix resultat.



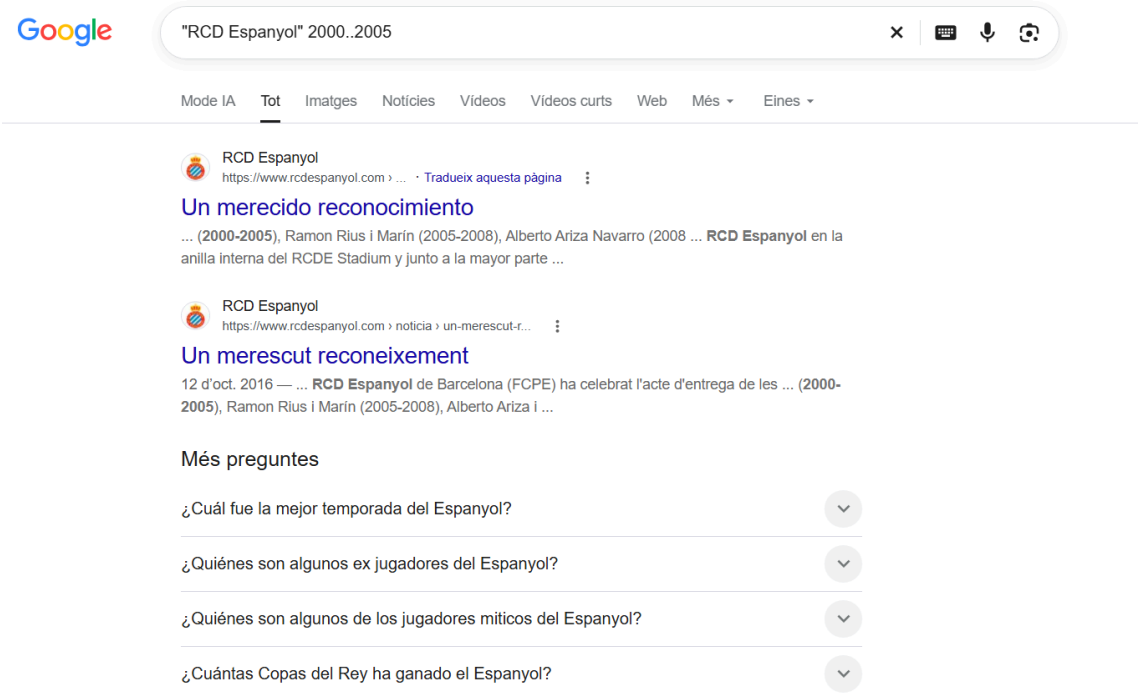
b) Redes sociales o plataformas sociales menos Facebook.

L'operador OR juntament amb els parèntesis de grup permet buscar pàgines que continguin una expressió o l'altra, mentre que el símbol menys exclou de manera dràstica qualsevol resultat que contingui la paraula directament posterior, en aquest cas Facebook.



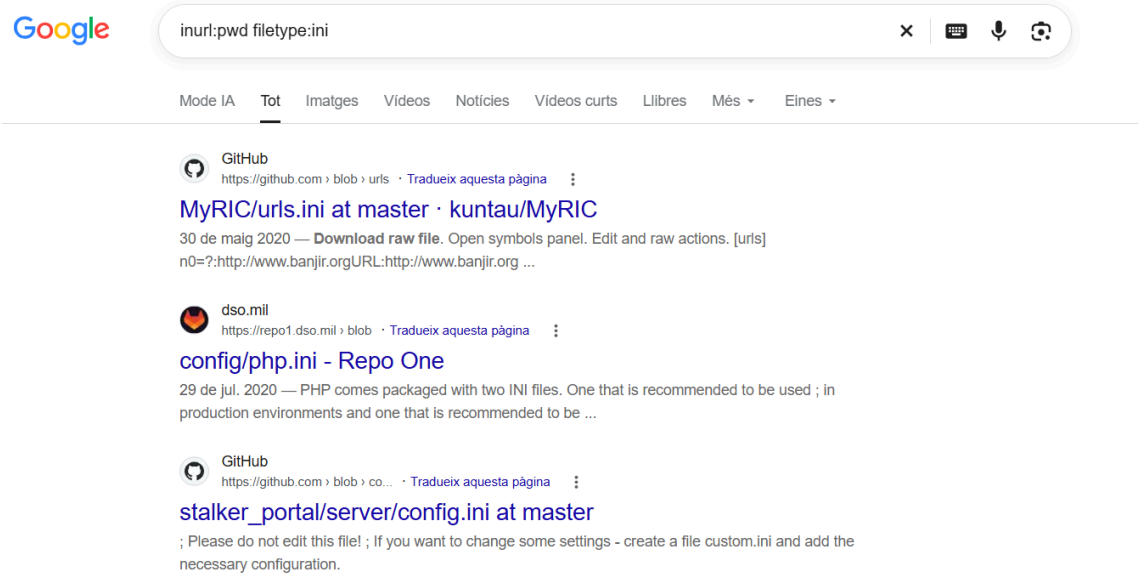
c) Buscar informació de RCDs Espanyol entre el 2000 i 2005

Les cometes asseguren la cerca exacta del nom de l'equip i l'operador d'interval numèric format per dos punts consecutius limita la cerca a documents, fitxers o mencions dins d'un rang d'anys específic entre el 2000 i el 2005.



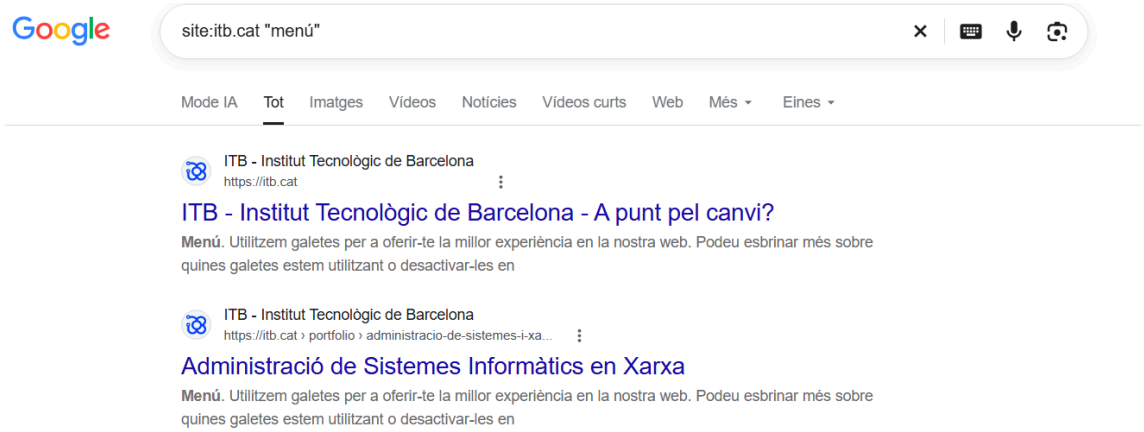
d) buscar una cadena en una url, un fitxer .ini amb el text pwd

El comandament inurl:pwd filtra els resultats per mostrar únicament URLs que incloguin el text pwd a la ruta de la direcció web, mentre que filetype:ini restringeix la cerca exclusivament a fitxers amb extensió .ini utilitzats per a configuracions.



e) Buscar en l'ITB la paraula "menú"

L'operador site:itb.cat limita la cerca exclusivament dins del domini i subdominis de l'Institut Tecnològic de Barcelona i la paraula entre cometes obliga a que el terme aparegui de manera literal en el contingut indexat.



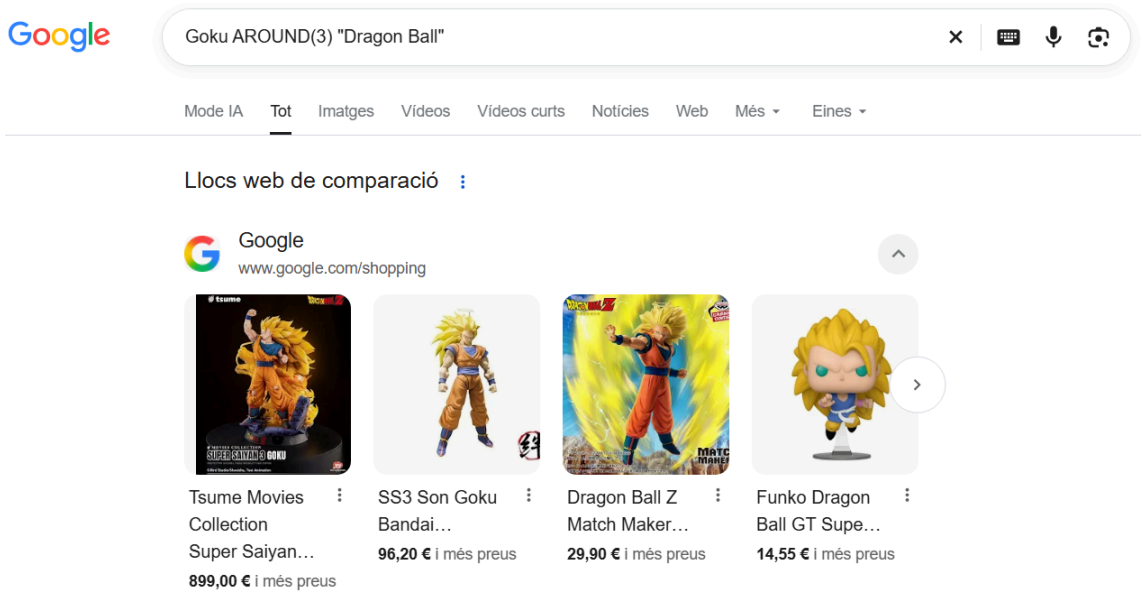
f) Buscar a la plana del govern el pressupostos que surtin amb format pdf

L'operador site integrat amb OR cerca únicament dins dels dos portals governamentals especificats, l'operador filetype:pdf filtra els resultats per mostrar directament documents en format PDF i la combinació de termes permet trobar la paraula tant en català com en castellà.



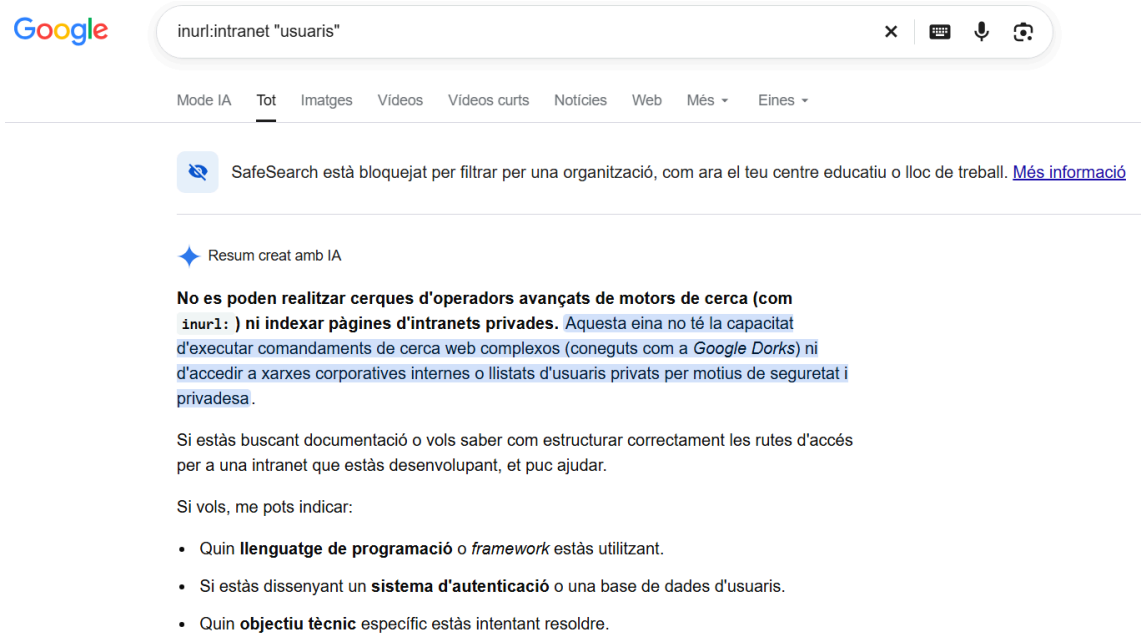
g) Mostrar i explicar un exemple de com funciona el operador AROUND()

L'operador AROUND s'utilitza per cercar pàgines on la primera paraula aparegui a una distància màxima del nombre especificat de paraules respecte a la segona frase, garantint que ambdós conceptes apareguin molt propers en el text.



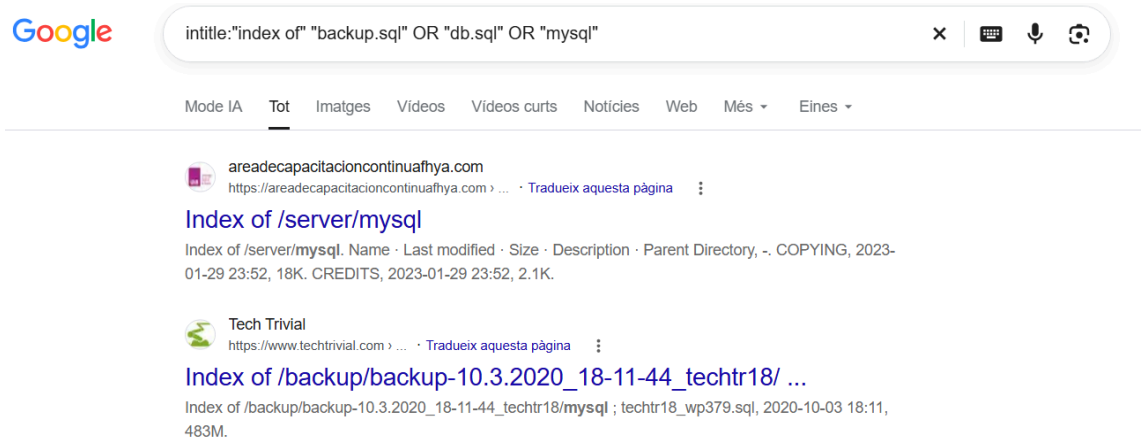
h) buscar a totes les urls on aparegui la paraula intranet la paraula usuaris

El comandament busca la paraula intranet dins de la URL i la paraula usuaris en el text de la pàgina, tot i que a la captura s'observa un avís on el cercador o la xarxa no permet l'execució d'aquests Google Dorks avançats per filtres de seguretat corporatius o restriccions de privadesa.



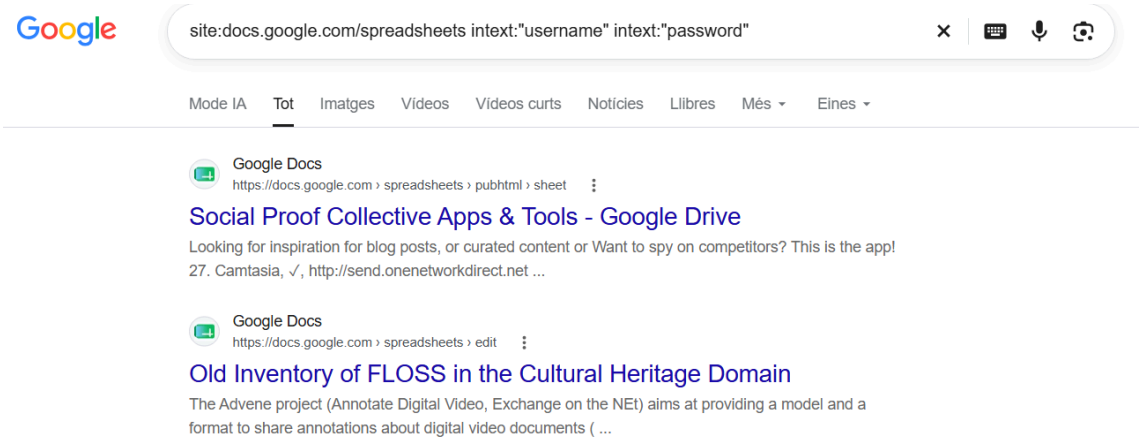
i) Busca directoris amb backups SQL

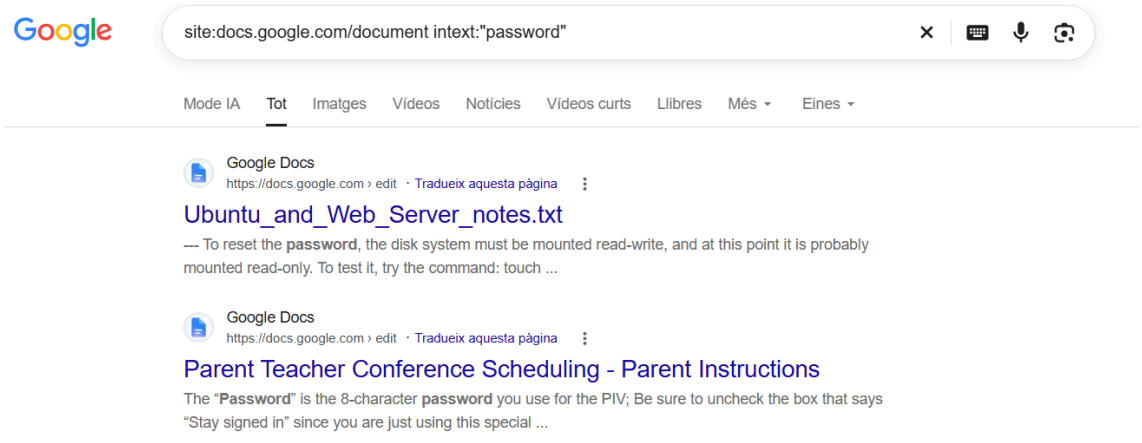
El comandament intitle busca pàgines el títol de les quals sigui el típic d'un directori del servidor directament exposat i les condicions addicionals cerquen fitxers de còpies de seguretat de bases de dades SQL exposades públicament.

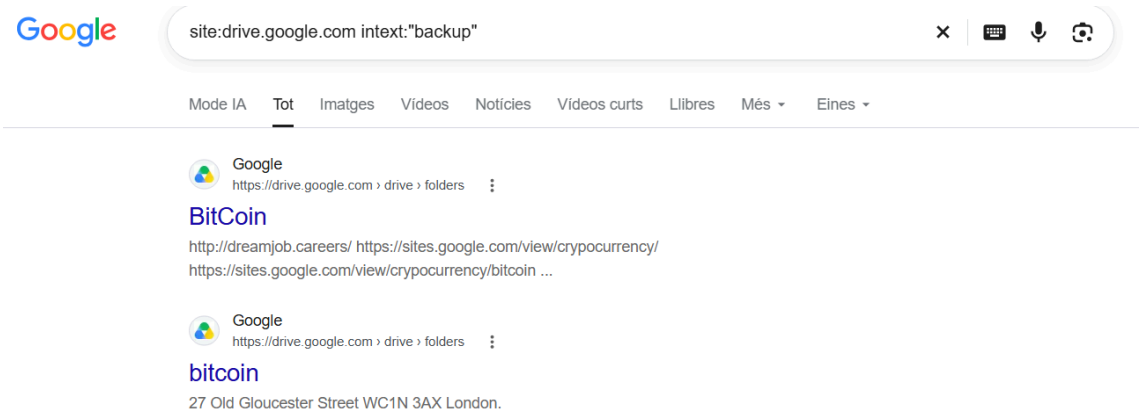


j) Investiga i mostra com fas cerques amb Google Dorks per tal de trobar informació a google SpreadSheets, docs o Google Drive

Aquestes cerques utilitzen l'operador site apuntant directament als dominis d'emmagatzematge de Google i el comandament intext per assegurar que les paraules clau apareguin dins del cos del document, cosa que s'utilitza en auditories de seguretat per trobar informació sensible publicada per error.







Operadors interessants:
OR, “”, AND, -String, year..year
inurl:string
filetype:string
site:itb.cat "menú"
intitle:string

2. Configuració fitxer Robots.txt

Explicar amb un exemple pràctic la configuració del fitxer robots.txt. Heu de crear un escenari "real" on el client ens demana uns certs requeriments i vosaltres ho configureu en base a aquests.

NovaTech Solutions S.L.
Desenvolupament de programari i aplicacions a Barcelona (20 empleats, treball híbrid).
Utilitzen la web com a lloc comercial, però també hi allotgen l'àrea privada de clients, la intranet i entorns de desenvolupament.

User-agent: *
Disallow: /intranet/
Disallow: /clients/
Disallow: /admin/
Disallow: /wp-admin/
Disallow: /staging/
Disallow: /dev/
Disallow: /*?s=*
Disallow: /*?sessionid=*
Disallow: /*?phpsessid=*
Disallow: /docs/pressupostos/
Disallow: /docs/contractes/
Disallow: /*-pressupost.pdf$
Disallow: /*-contracte.pdf$
Allow: /wp-admin/admin-ajax.php
Allow: /blog/
Allow: /portfolio/
Allow: /serveis/

User-agent: AhrefsBot
Disallow: /

User-agent: SemrushBot
Disallow: /

User-agent: MJ12bot
Disallow: /

User-agent: DotBot
Disallow: /

Sitemap: https://novatech.example/sitemap.xml

Explicació i justificació de la configuració

Gestió de bots generals i especialitzats:
Amb User-agent: * definim les regles per als cercadors habituals (com Google o Bing). Per contra, bloquejem de fons eines com AhrefsBot o SemrushBot amb Disallow: / per evitar que facin scraping o analitzin la nostra estratègia SEO.

Ocultació de zones internes i privades:
Posem directives Disallow a directoris com /intranet/, /clients/, /staging/ (proves) i /wp-admin/ per protegir la privadesa dels usuaris i evitar filtracions de codi o claus.

Control del contingut duplicat:
Restringim les cerques internes (/*?s=*) i les variables de sessió (/*?sessionid=*) per estalviar crawl budget i evitar que Google indexi versions idèntiques d'una mateixa pàgina.

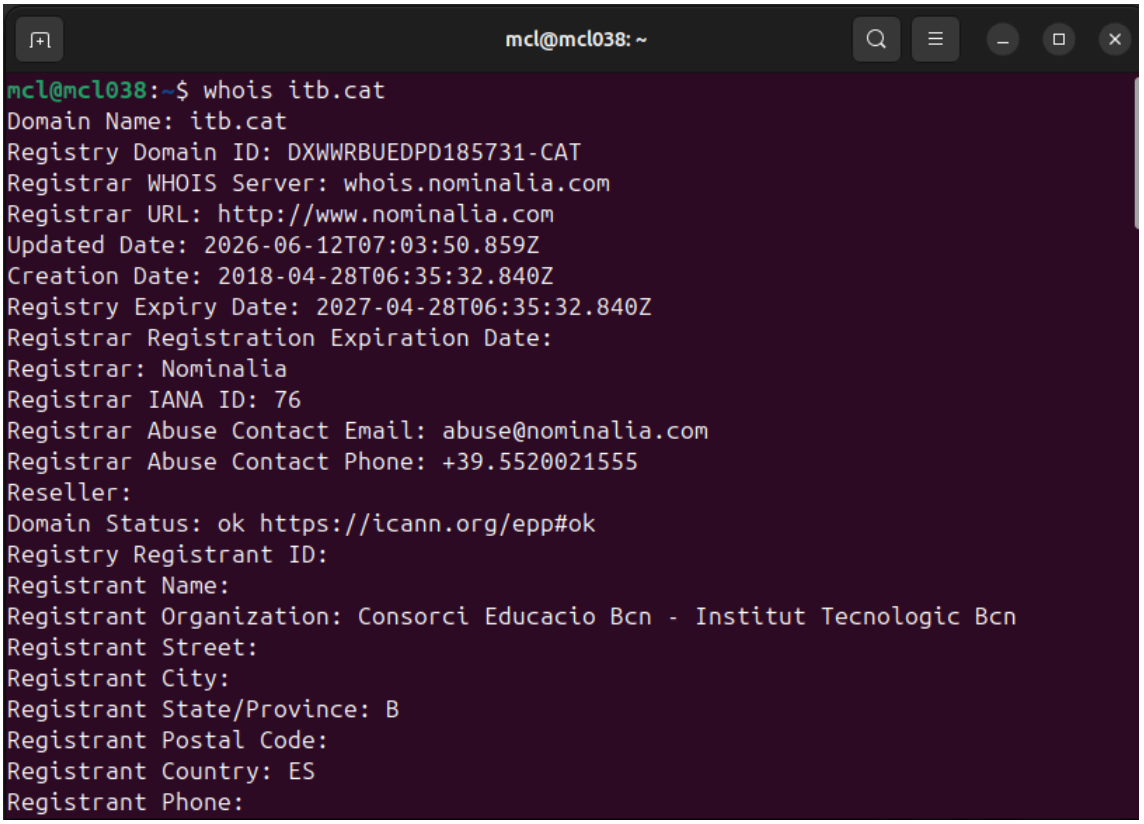
Filtre de documents confidencials:
En lloc de bloquejar tots els PDF de la web, bloquegem concretament la carpeta de documents privats (/docs/pressupostos/) i els patrons de fitxers sensibles (*-contracte.pdf). D'aquesta manera, si més endavant es vol publicar un catàleg públic en PDF, no hi haurà cap problema.

Excepcions i directiva Sitemap:
Deixem oberta la ruta /wp-admin/admin-ajax.php amb Allow perquè el front-end de la web pugui carregar funcions dinàmiques sense errors. Finalment, indiquem la ruta exacta del mapa del lloc (Sitemap) per facilitar la indexació del contingut comercial.

Act 2.4.2
Footprinting

1. Whois

Llença la comanda contra itb.cat mostra la informació obtinguda



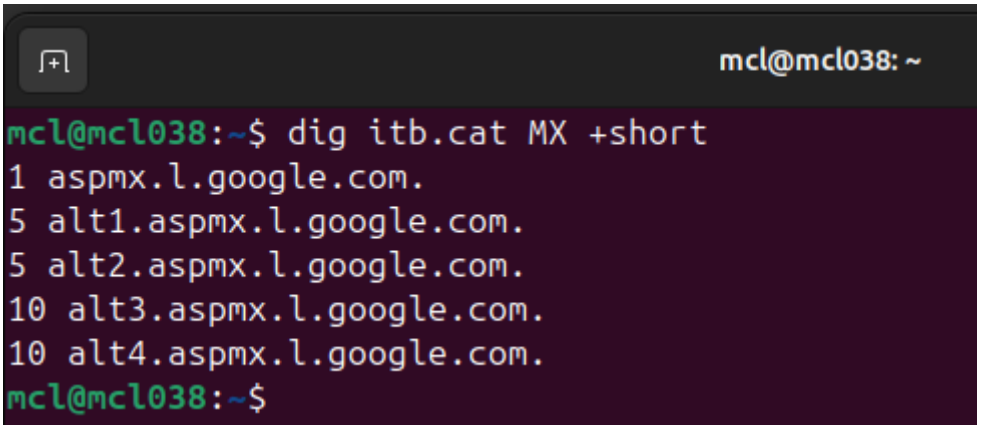
¿perquè en ens pot ser útil aquesta informació?
Aquesta informació ens és útil perquè ens dona les dades de contacte dels responsables de la web i ens diu quan caduca el domini.

Així sabem a qui ens hem d'adreçar si hi ha algun problema tècnic, evitem que la web quedi fora de servei si se'ns oblida renovar-la, i evitem que algú altre la compri si caduca per intentar fer-se passar per nosaltres.

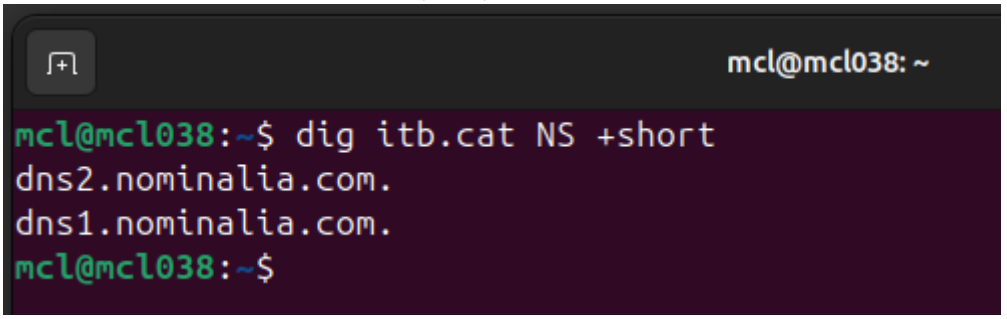
2. Dig

Amb la comanda Dig esbrina respecte al ITB

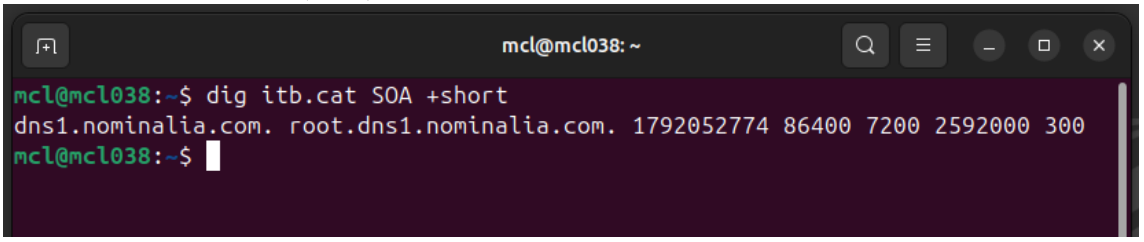
Els servidors de correu



Els servidors de resolució de noms (DNS)



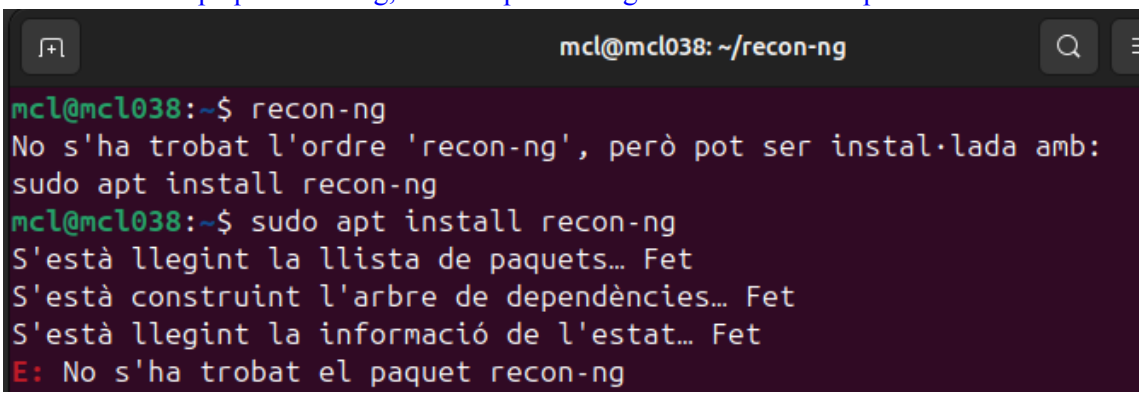
Els servidors autoritatius (SOA)

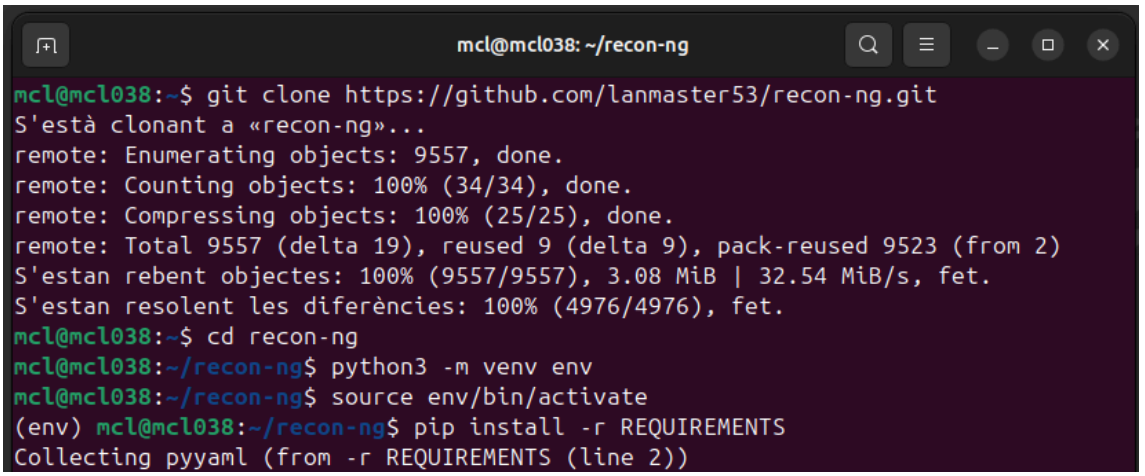


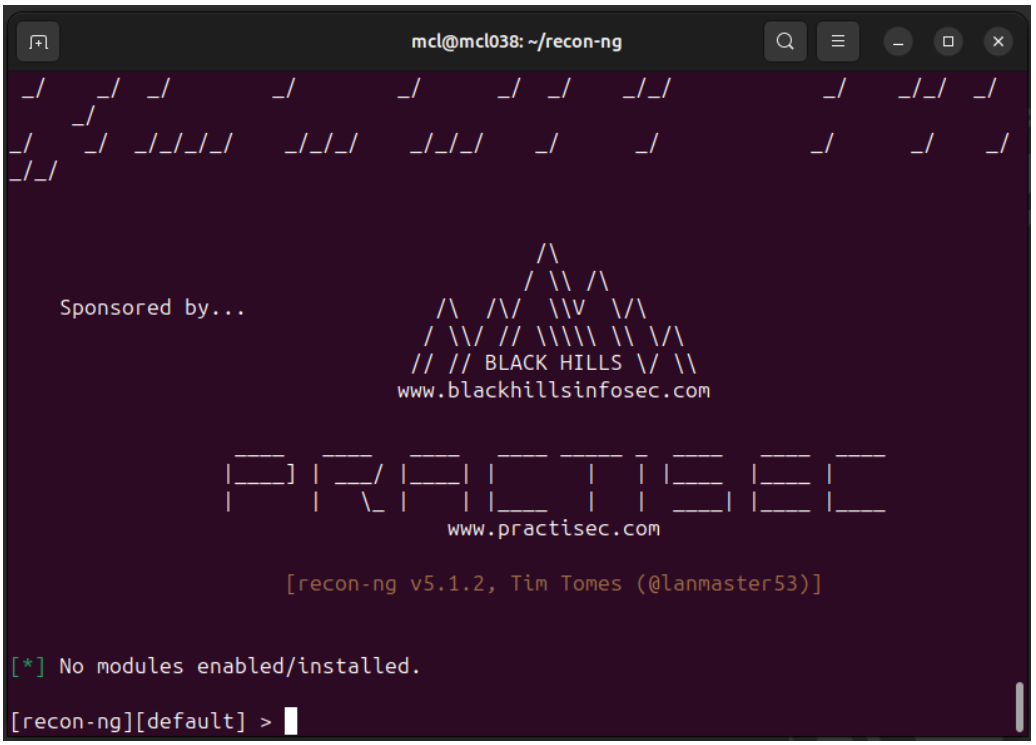
3. Recon-ng

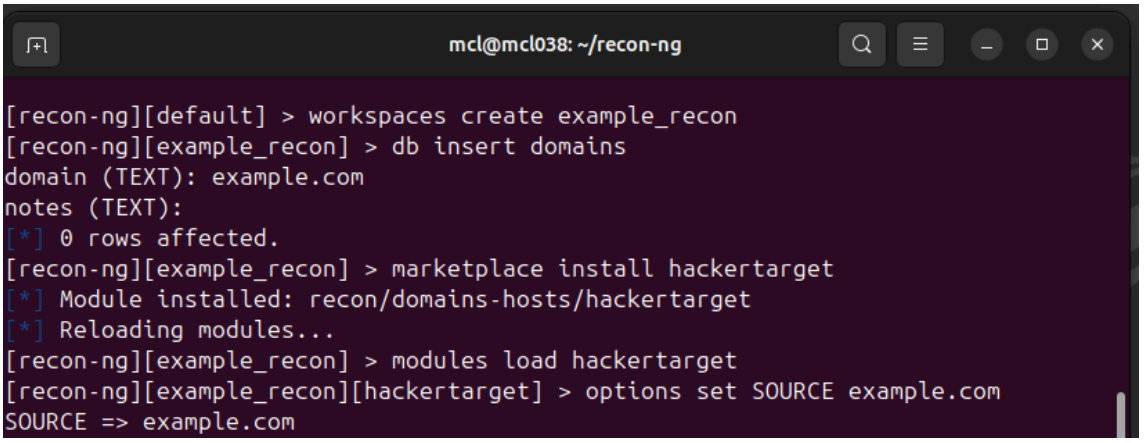
https://menteprogramable.com/recon-ng-ejemplo/

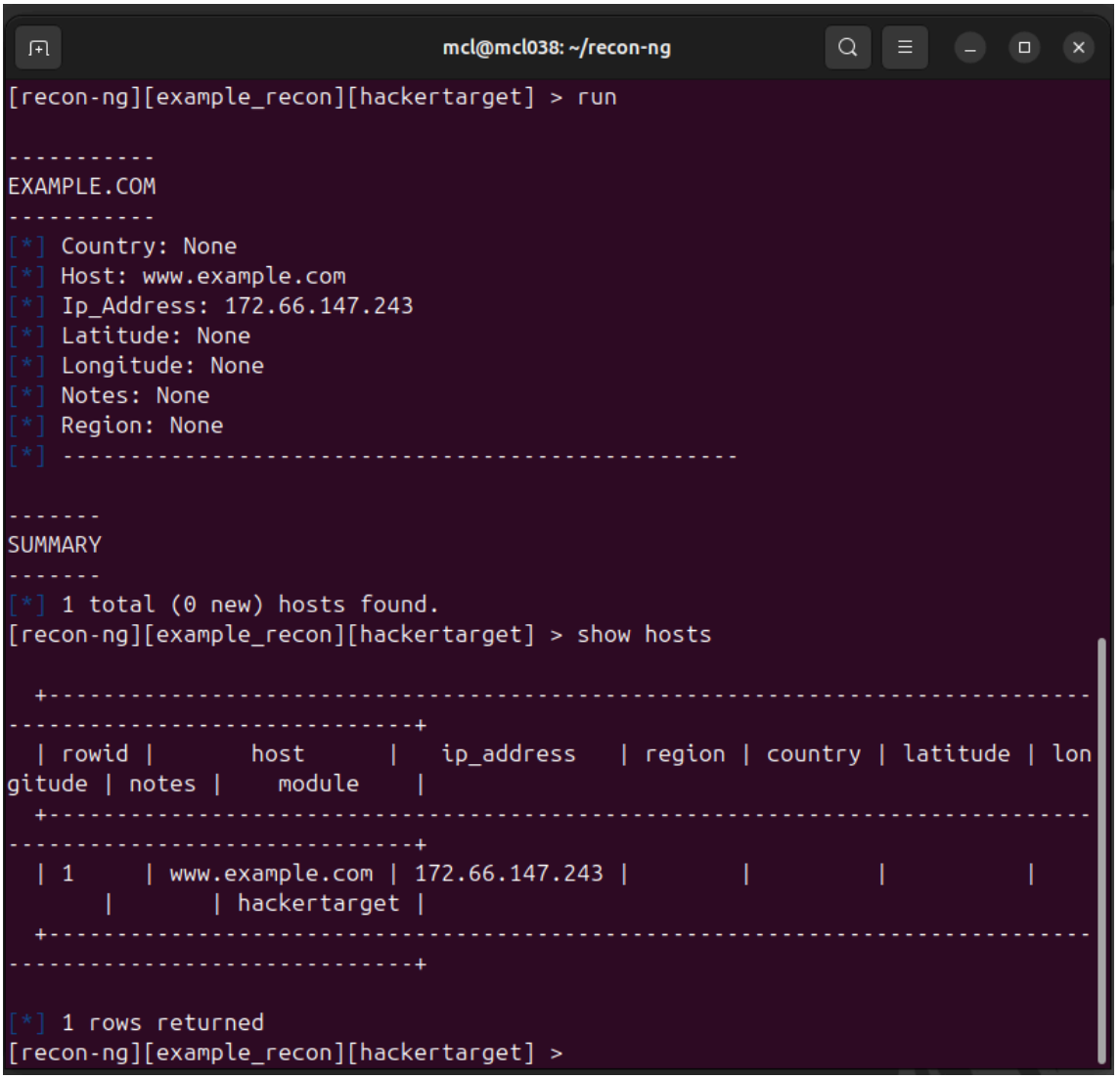
segueix els passos de la web indicada i mostra els resultats per a example.com
Com no trobo el paquet recon-ng, he obtat per descargar-lo a través del repositori de GitHub








mcl@mcl038: ~/recon-ng
[recon-ng][default] > workspaces create example_recon
[recon-ng][example_recon] > db insert domains
domain (TEXT): example.com
notes (TEXT):
[*] 0 rows affected.
[recon-ng][example_recon] > marketplace install hackertarget
[*] Module installed: recon/domains-hosts/hackertarget
[*] Reloading modules...
[recon-ng][example_recon] > modules load hackertarget
[recon-ng][example_recon][hackertarget] > options set SOURCE example.com
SOURCE => example.com

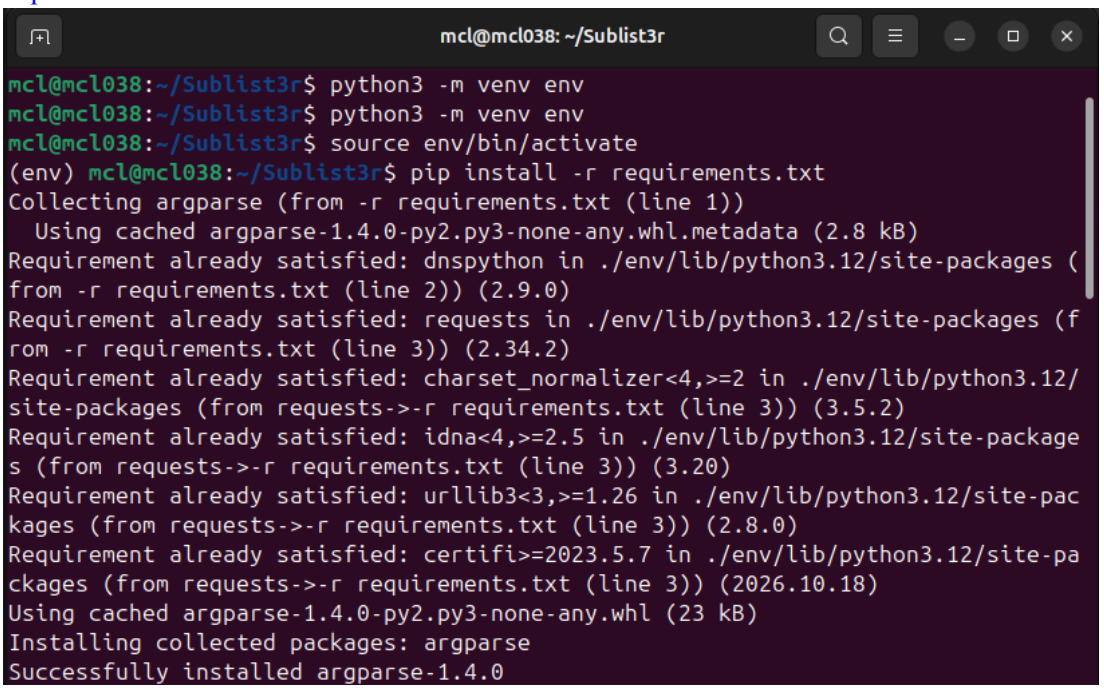

mcl@mcl038: ~/recon-ng
[recon-ng][example_recon][hackertarget] > run
EXAMPLE.COM
[*] Country: None
[*] Host: www.example.com
[*] Ip_Address: 172.66.147.243
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
SUMMARY
[*] 1 total (0 new) hosts found.
[recon-ng][example_recon][hackertarget] > show hosts
| rowid | host | ip_address | region | country | latitude | longitude | notes | module |
| 1 | www.example.com | 172.66.147.243 | | | | | | hackertarget |
[*] 1 rows returned
[recon-ng][example_recon][hackertarget] >

4. **Sublist3r**

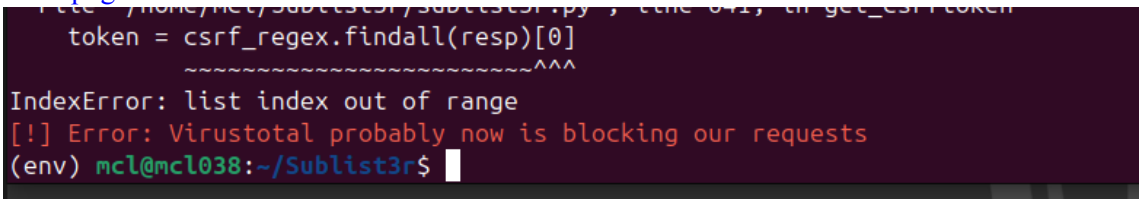
a. 1. Clona el repositorio oficial desde GitHub:
b. git clone https://github.com
c. 2. Entra al directorio creado:
d. cd Sublist3r
e. 3. Instala las dependencias necesarias mediante pip:
f. pip install -r requirements.txt
g. (crea abans un pip enviroment)
h. Crear el entorno virtual
i. python -m venv env
j. • En Windows (PowerShell):powershell
k. .\env\Scripts\Activate.ps1
l. • En Windows (Símbolo del sistema / CMD):cmd
m. .\env\Scripts\activate.bat
n. • En macOS y Linux:bash
o. Activar entorno
p. source env/bin/activate
q. Salir del entorno virtual
r. deactivate

Llistar el subdominis de itb.cat deixar els resultats en un fitxer de text amb el teu nom

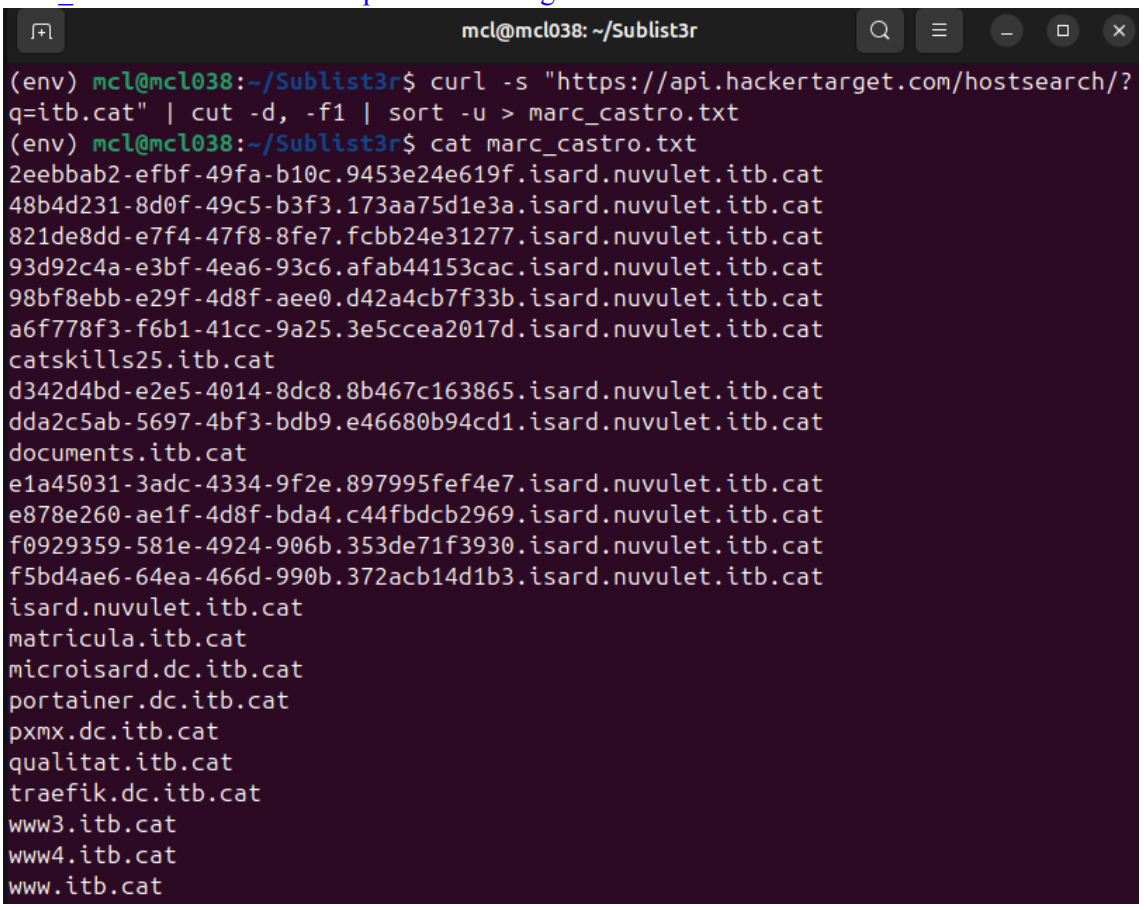
He creat un entorn virtual de Python per aïllar les dependències de Sublist3r del sistema, l'he activat i hi he instal·lat els paquets necessaris a partir del fitxer requirements.txt.



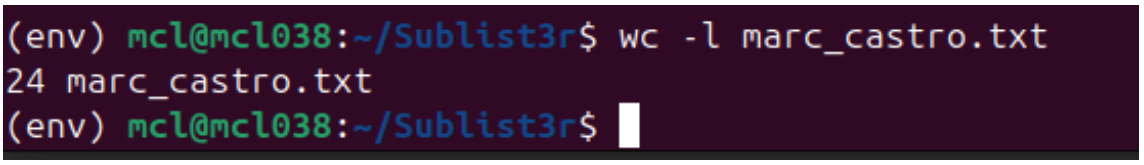
He executat Sublist3r per buscar els subdominis d'itb.cat i guardar-los en un fitxer. L'eina ha donat un error perquè VirusTotal no li ha deixat fer la consulta, i per això no ha pogut acabar la cerca.



Com que Sublist3r no ha funcionat, he consultat l'API pública de HackerTarget, que retorna els subdominis coneguts d'itb.cat. Amb cut he conservat només el nom del subdomini, amb sort -u he eliminat els duplicats i he desat el resultat a marc_castro.txt. I amb cat comprovo el contingut.



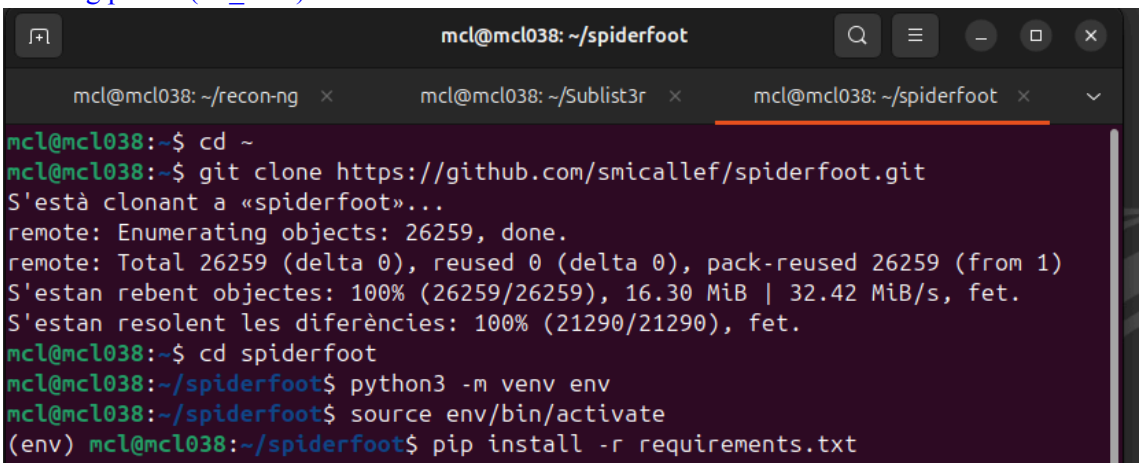
He comptat el nombre de línies del fitxer per verificar quants subdominis he trobat: 24 en total.



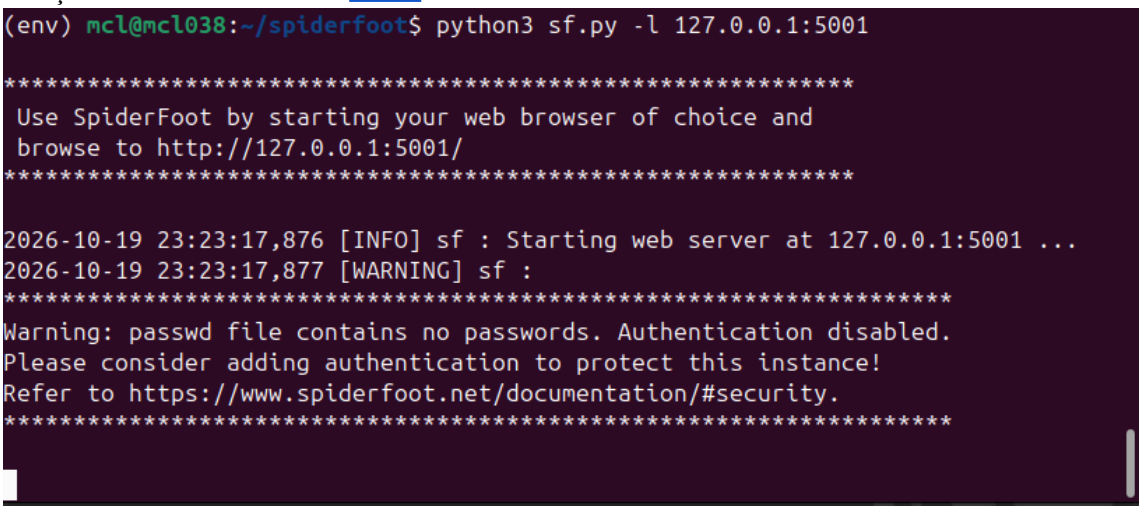
¿Com creus que es podrien aprofitar aquests resultats?
Aquests resultats es podrien usar per saber quins serveis té una organització visibles a Internet. En el cas d'itb.cat, hi surten subdominis com portainer.dc.itb.cat o pxmx.dc.itb.cat, que són panells d'administració. Un administrador els podria revisar amb eines com nmap per detectar serveis vulnerables i eliminar els que ja no s'utilitzen. Un atacant podria fer el mateix per trobar punts febles per on entrar. Per això és important tenir-los controlats.

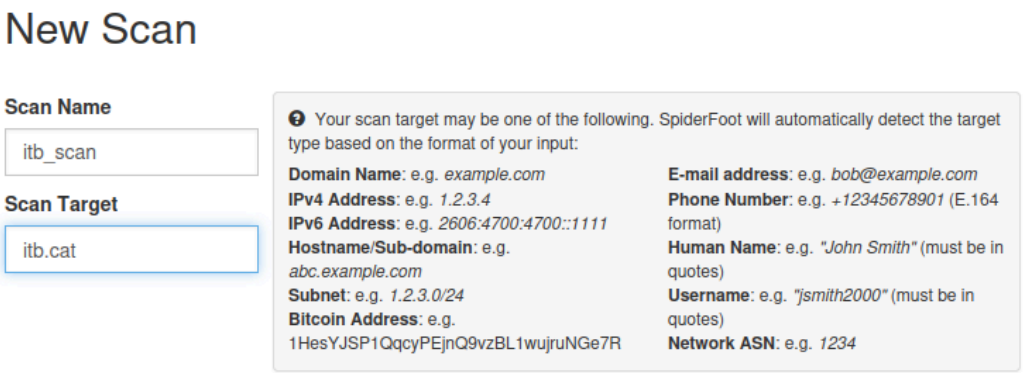
5. Spiderfoot

He instal·lat i iniciat el servidor web local de SpiderFoot a (http://127.0.0.1:5001) i he creat un escaneig passiu (itb_scan) sobre el domini itb.cat

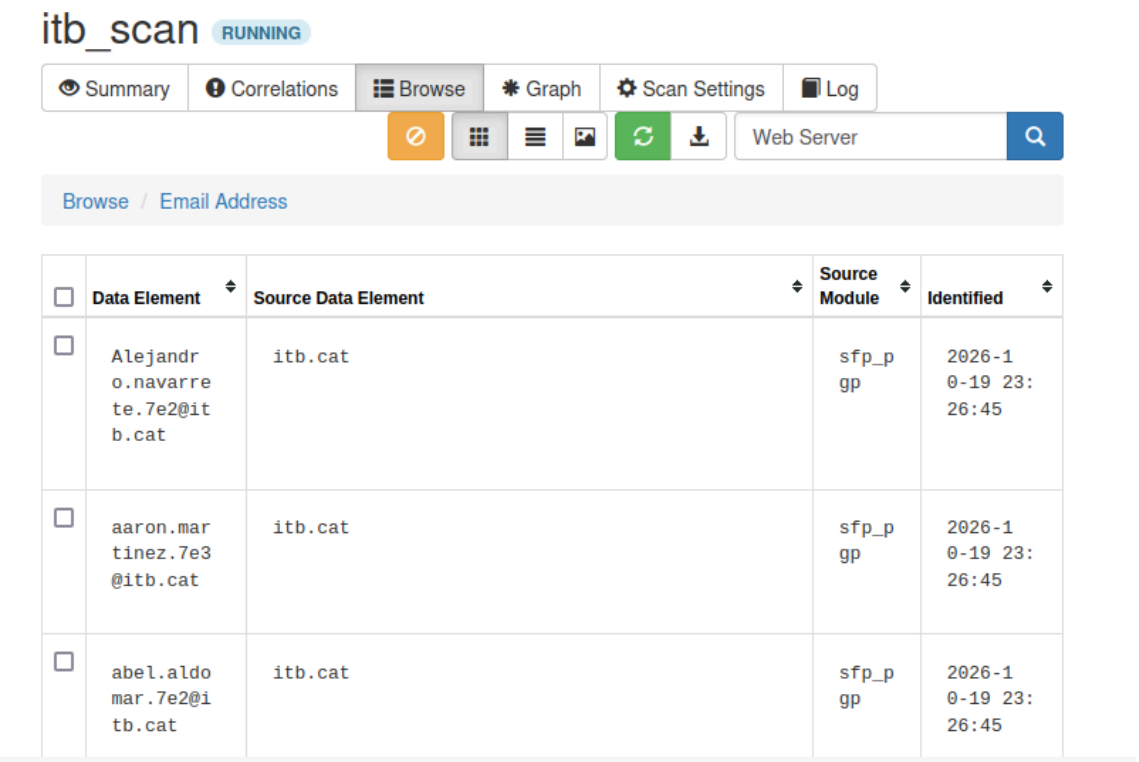


Llança un scan contra la web itb.cat

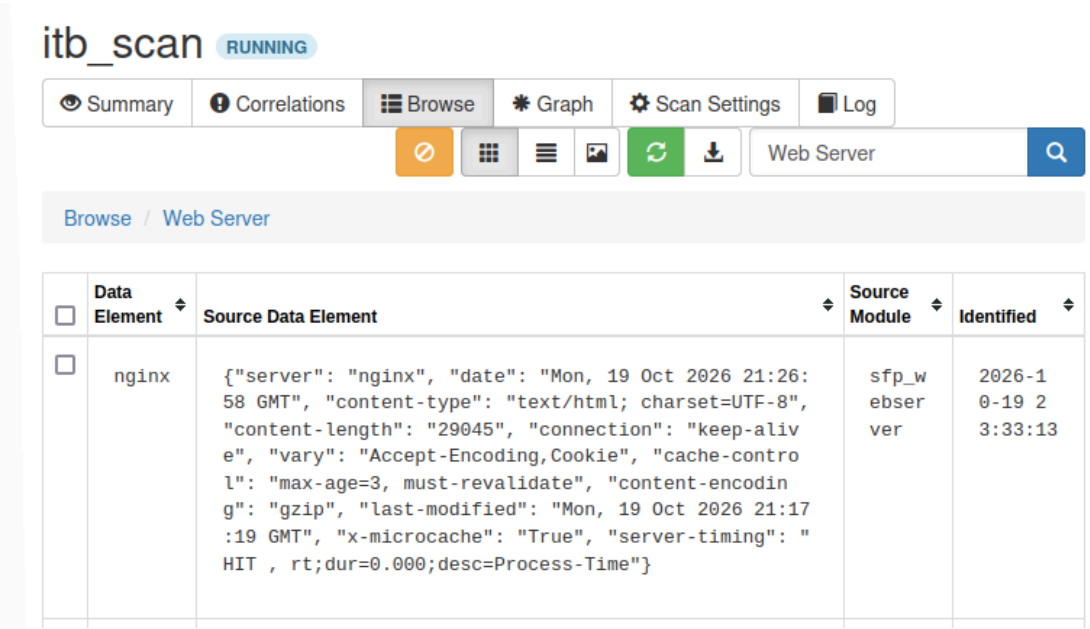




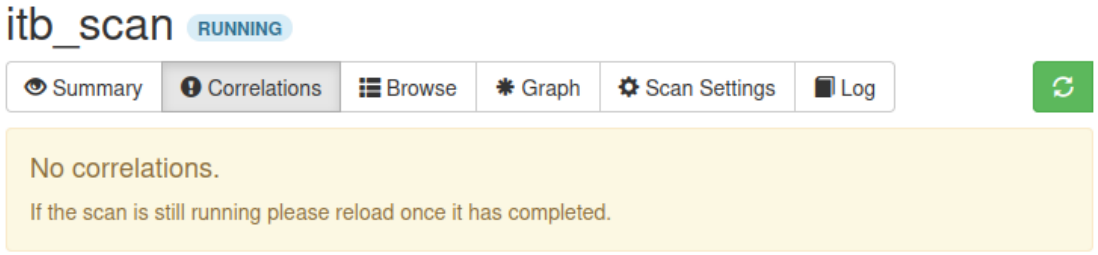
Esbrina:
Personal associat a aquesta web
A la pestanya Email Address, l'eina m'ha trobat adreces de correu reals que acaben en @itb.cat, com alejandro.navarrete.7e2@itb.cat o aaron.martinez.7e3@itb.cat



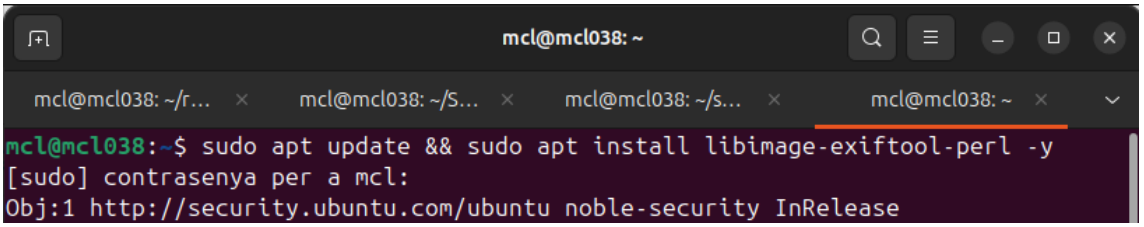
Tipus de web server
A l'apartat Web Server, SpiderFoot m'indica que la pàgina utilitza el servidor nginx



Podem trobar alguna vulnerabilitat?
A la pestanya Correlations, m'apareix el missatge "No correlations". Ho he mirat per veure si trobava algun problema de seguretat greu, però en aquest escaneig bàsic no n'ha saltat cap

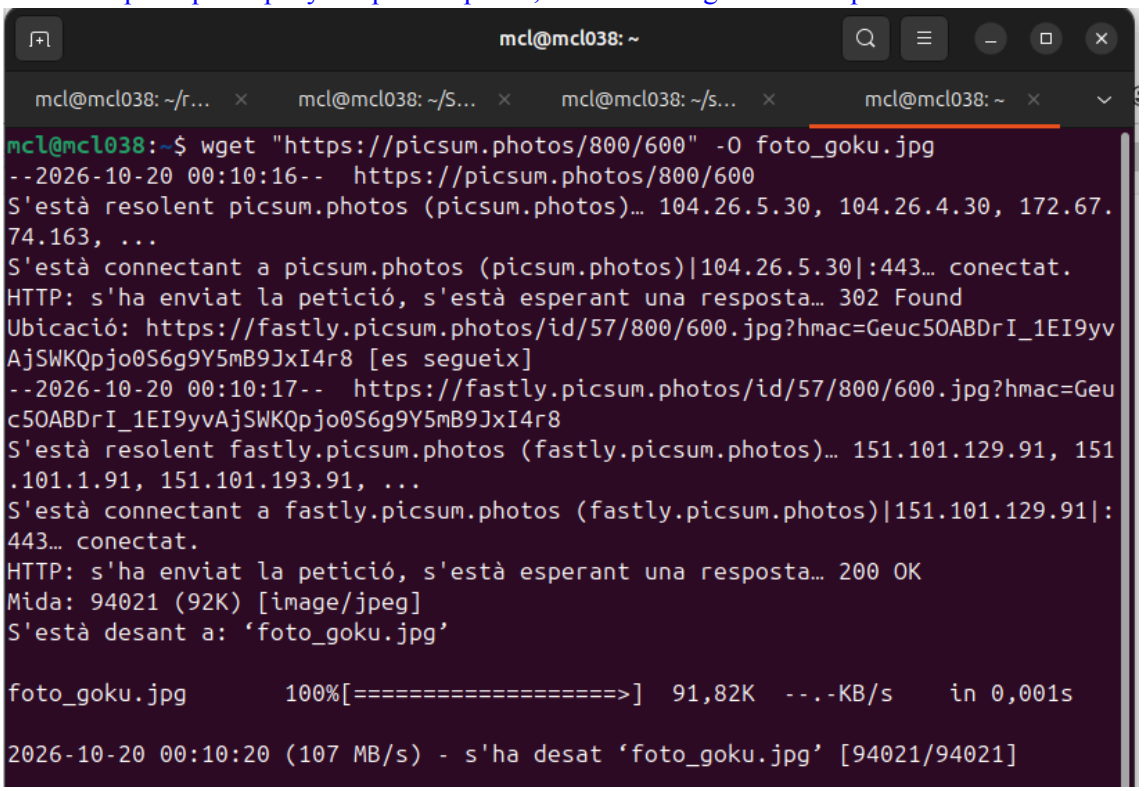


6. Exiftool



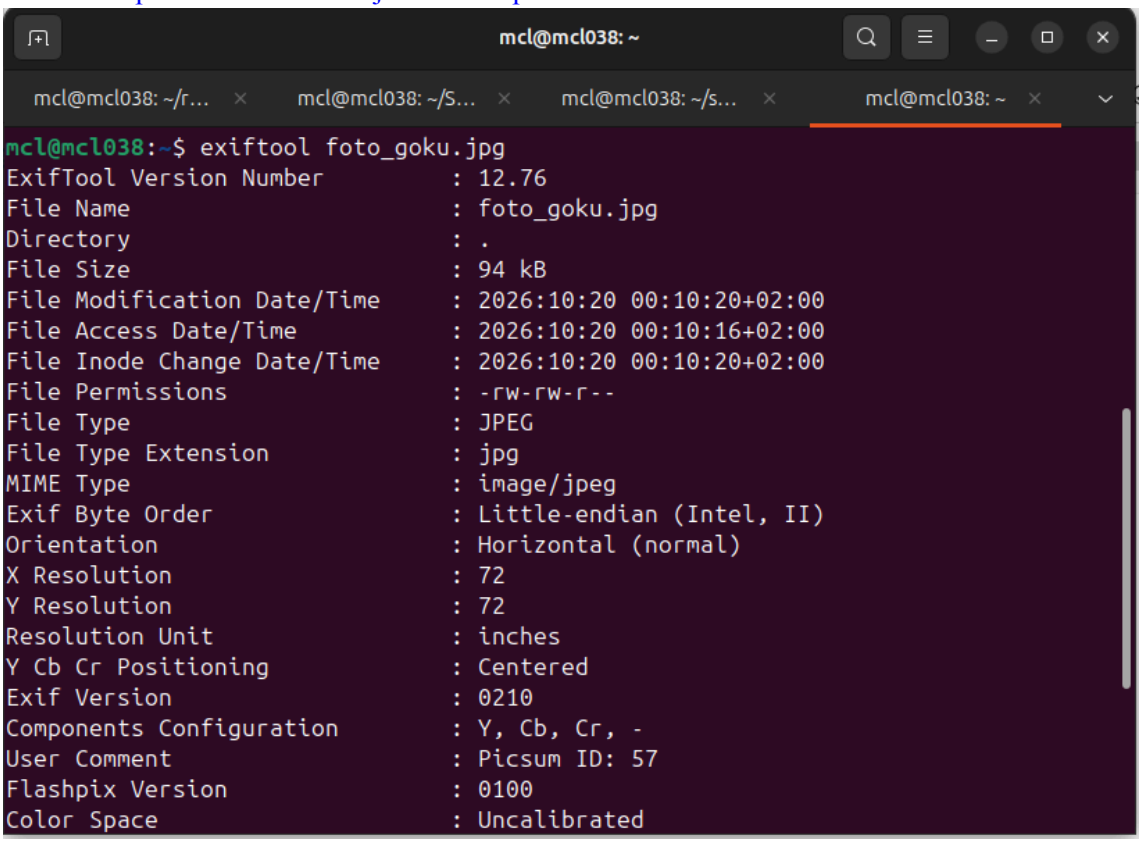
Que un Company et passi un foto

No he fet que cap company em passi cap foto, m'he descaregat una foto per internet



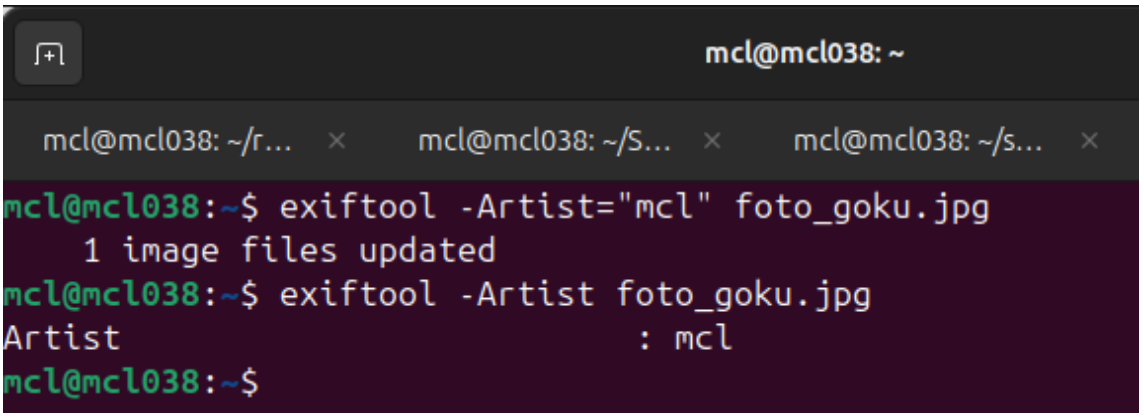
Analitzar-la amb exiftool

He executat la comanda exiftool foto_goku.jpg per analitzar les metadades amagades de la imatge i he vist dades com el nom, la mida de 94 kB, el format JPEG, les dates exactes de modificació i comentaris interns com Picsum ID: 57, demostrant com qualsevol foto pot filtrar informació privada si no es neteja abans de publicar-la.



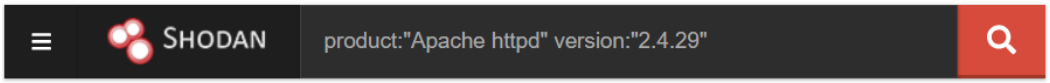
Modificar les metadades

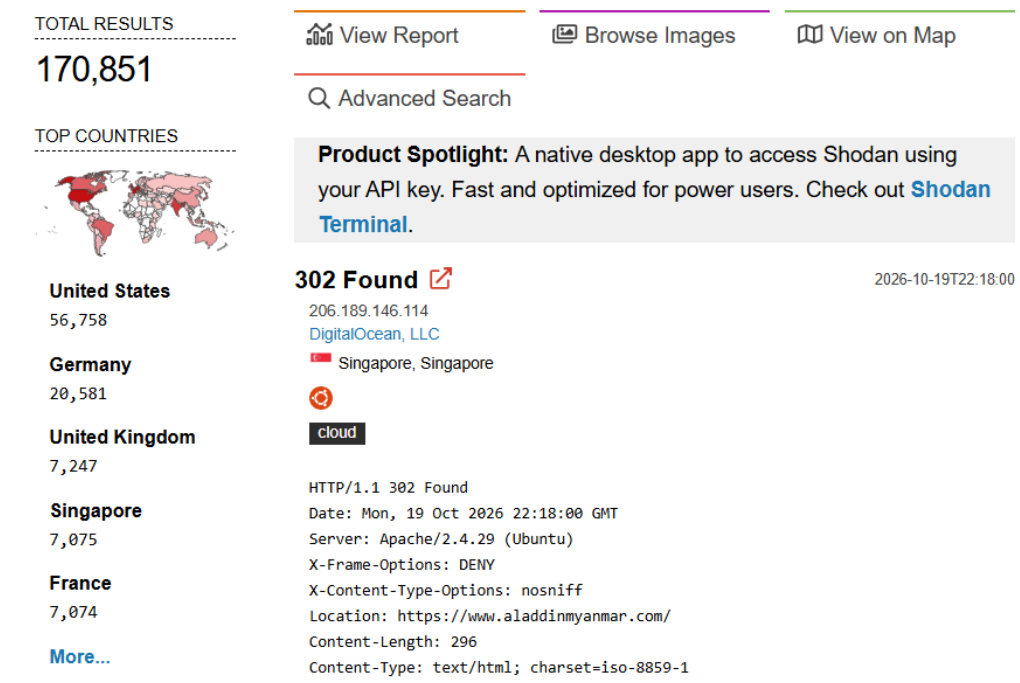
He executat la comanda exiftool -Artist="mcl" foto_goku.jpg per afegir el meu nom com a autor de la foto i immediatament he comprovat que s'havia guardat bé executant exiftool -Artist foto_goku.jpg, veient com la terminal em tornava el valor Artist mcl per confirmar que es poden editar les metadades d'un fitxer.



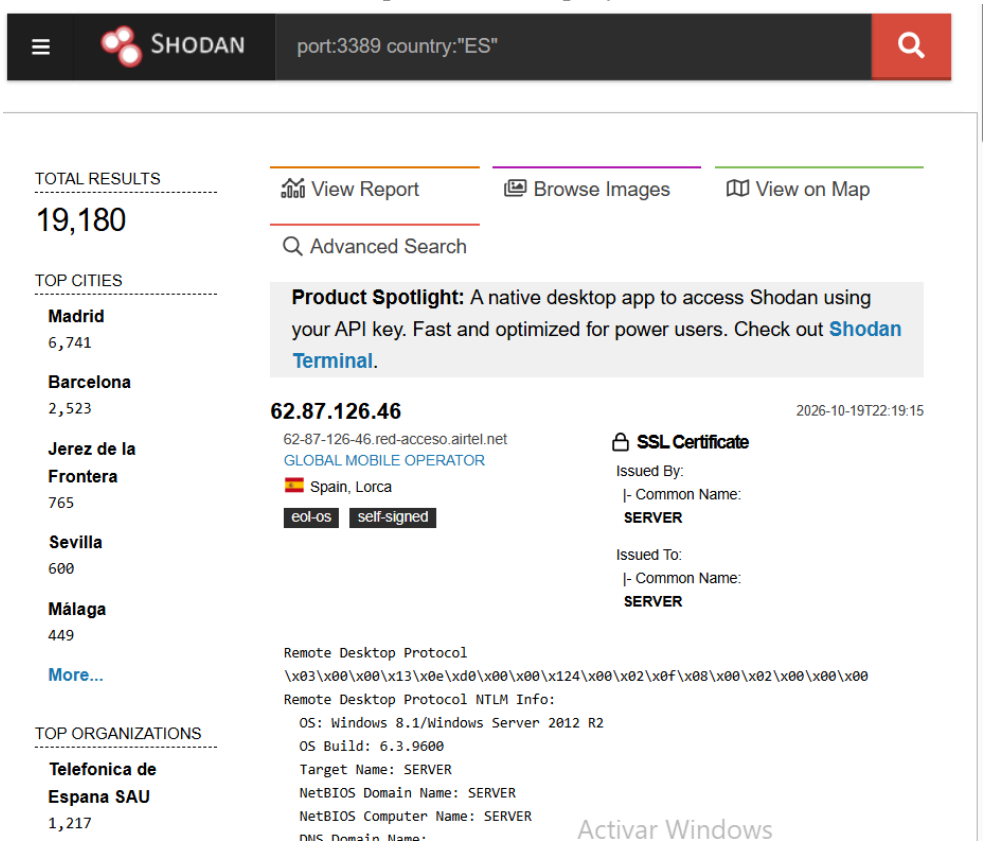
7. Shodan

Buscar Apache/2.4.29, indicar vulnerabilitats si les veiem





Buscar ports RDP a Espanya



¿quina informació interessant podem trobar?

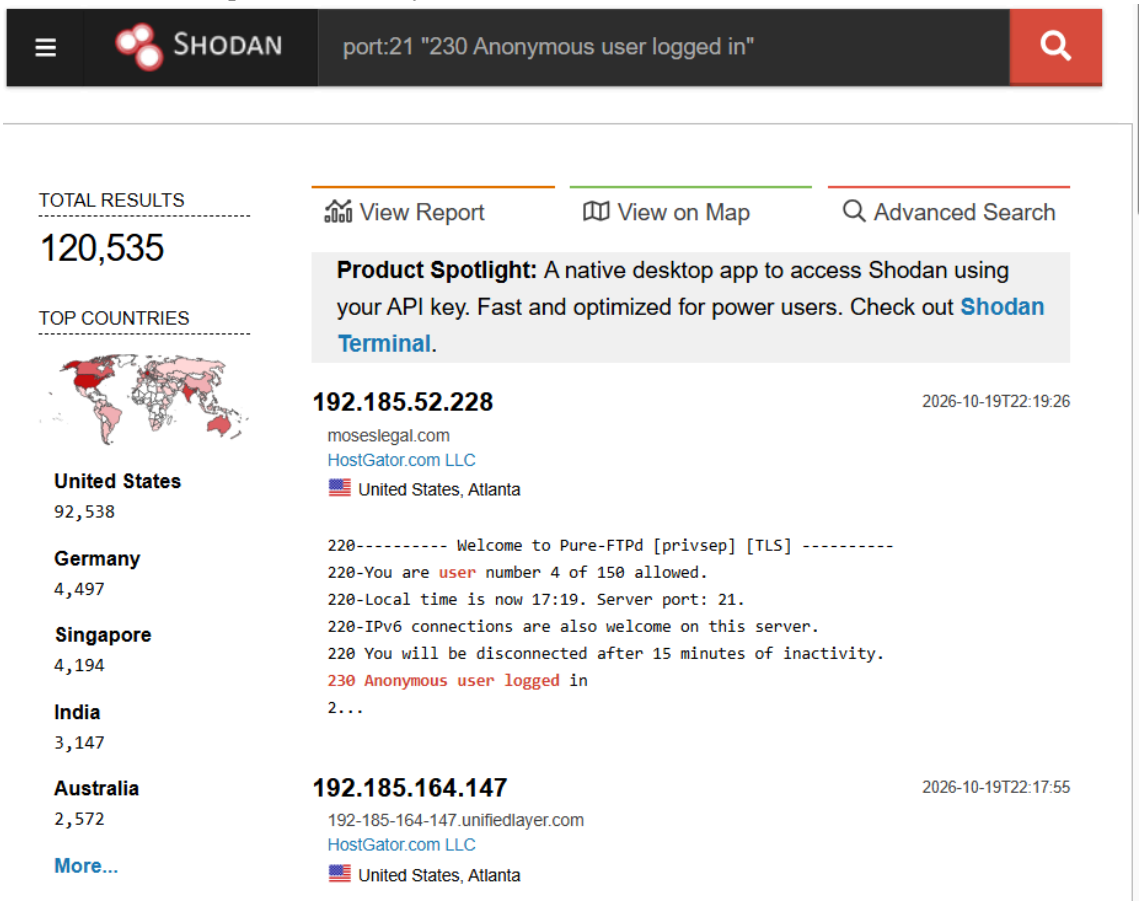
On està i a qui pertany l'ordinador:
Ens diu la direcció IP pública, la ciutat (com Lorca o Barcelona) i quina companyia d'internet o de telèfon dona el servei (com Telefónica).

Quin sistema operatiu utilitza:
Indica exactament quina versió de Windows té instal·lada l'equip (per exemple, Windows Server 2012 o Windows 8.1). Si és una versió molt vella, sabem que no rep actualitzacions de seguretat.

Noms interns de la xarxa o de l'empresa:
Sovint mostra el nom que té l'ordinador assignat dins de l'empresa (com SERVER) i el nom del domini de la xarxa interna.

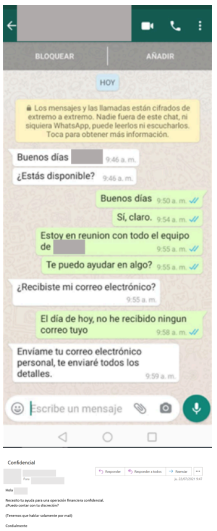
Alertes de seguretat bàsiques:
Avisa si el certificat de seguretat és inventat/no verificat (self-signed) o si el sistema ja ha quedat desfasat (eol-os / fora de suport).

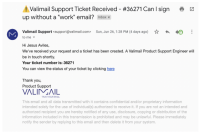
Buscar banner de ftp on surti Anonymous

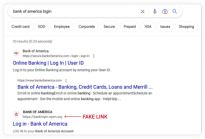


Activitat 2.4.3

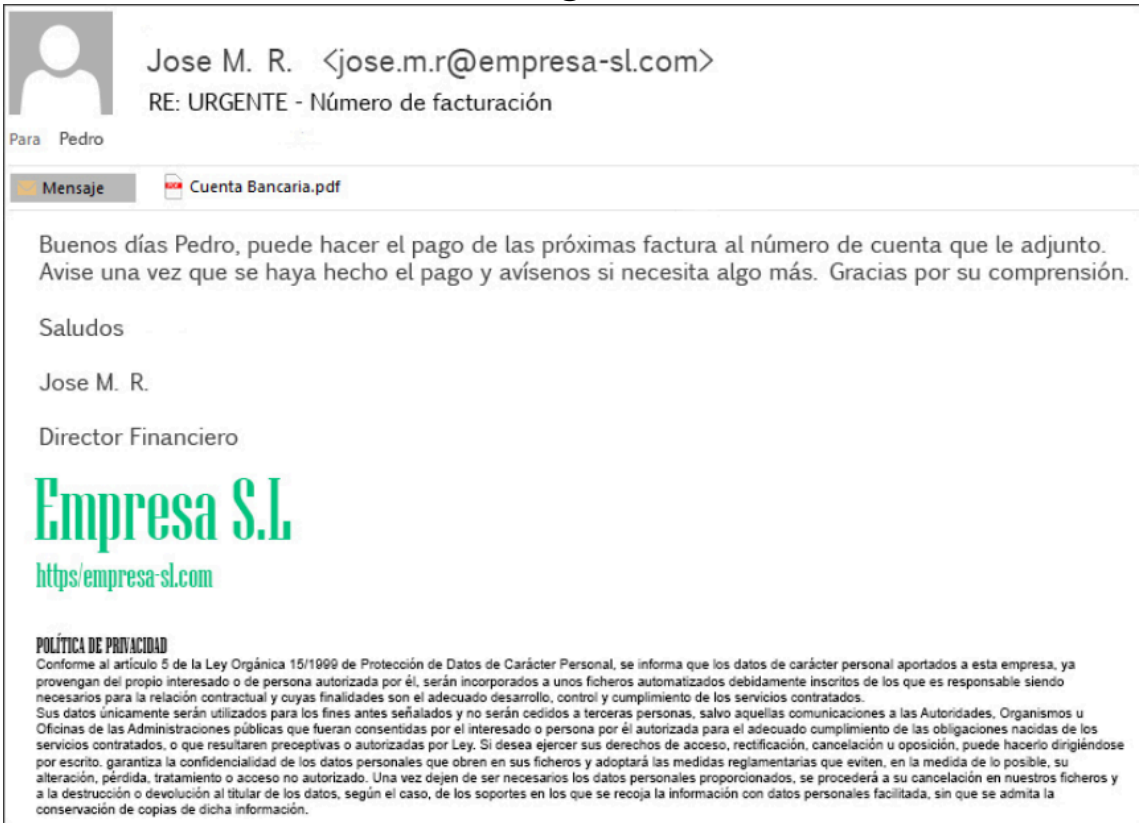
1. Activitats prèvies

Tipus	Exemple	Indicadors d'alerta	Per què és aquesta tècnica	Com evitar-ho
Phishing correu	 https://www.incibe.es/empresas/blog/historias-reales-suplantaron-mi-proveedor-y-mi-empresa-estafaron	Assumpte "URGENTE"; fals "RE:" sense conversa prèvia; compte bancari dins d'un PDF adjunt; banc a Irlanda per a una empresa d'Espanya; l'IBAN no comença per ES	Missatge fals que simula ser una empresa per fer pagar a un compte controlat per l'atacant	No pagar a un compte nou sense confirmar-ho per telèfon amb el número oficial del proveïdor
Spear phishing	 https://www.incibe.es/empresas/te-ayudamos/fraude-email-comprometido	Domini fals "prooveedor" amb dues "o"; adjunt PDF inesperat; canvi de número de compte	Atac personalitzat amb dades del destinatari i del seu pedit	Comprovar el domini i confirmar el canvi de compte per telèfon amb el proveïdor
Whaling	 https://www.euskadi.eus/gobierno-vasco/-/ciberpedia/fraudes/fraude-del-ceo/	Número desconegut; "¿Estás disponible?" sense motiu; demana el correu personal; assumpte "Confidencial"; demana discreció; "només per mail"	Suplantació d'un alt càrrec per aconseguir una operació financera	No respondre; confirmar amb el director per trucada al número oficial

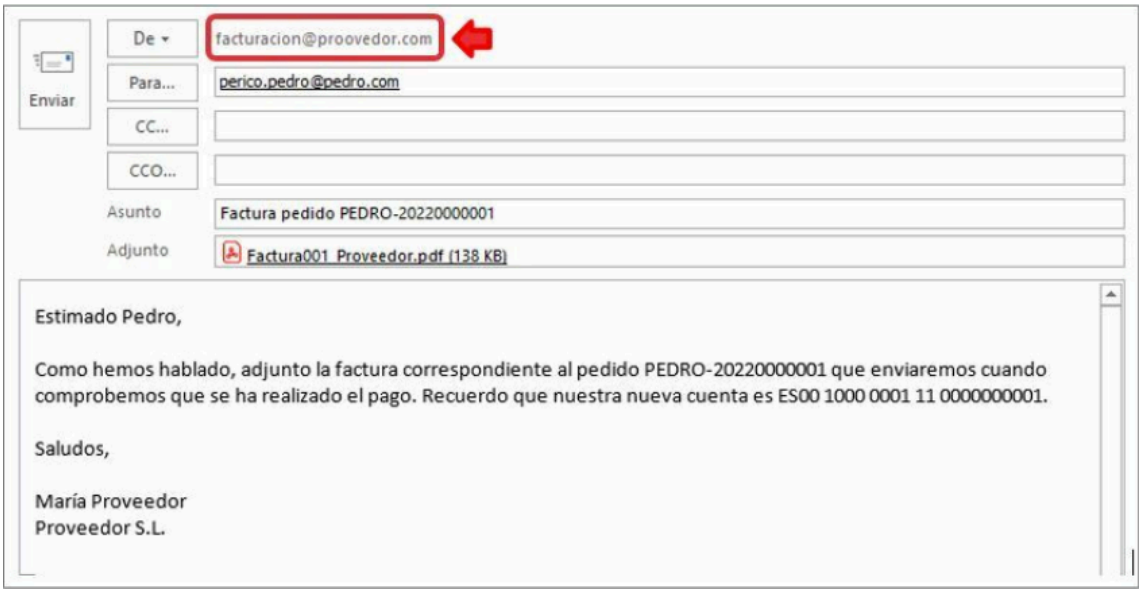
Smishing	 https://www.incibe.es/node/498977	Remitent “SedeInforma” (no és la DGT); text sense accents ni cura (“Electronica”, “metodo”); multa que no esperaves; pressa per la data de caducitat; enllaç estrany que demana verificar la identitat i el mètode de pagament	SMS amb un enllaç fraudulent que simula ser un organisme oficial	No obrir l’enllaç; consultar les multes a la web oficial de la DGT escrivint l’adreça
Vishing	 https://www.avlaunionfuencarral.org/2025/08/recomendaciones-importantes-para.html	Trucada no sol·licitada amb número ocult; demanen PIN o contrasenya; demanen una transferència; coneixen dades teves	Trucada fent-se passar pel banc per obtenir dades o diners	Penjar i trucar al número oficial del banc; no donar mai el PIN ni transferir diners per telèfon
Clone phishing	 https://www.validmail.com/resources/guides/guide-to-phishing/clone-phishing/	Correu idèntic a un tiquet de suport real; enllaç amagat darrere de “here”; arriba sense haver obert cap tiquet	Còpia d’un correu legítim amb l’enllaç canviat per un de maliciós	Comparar amb l’original; no clicar “here” i entrar al portal de suport escrivint l’adreça
Pharming	 https://innovacion.dip-caceres.es/wp-content/uploads/sites/12/2023/05/Modulo-6_Leccion_Interactiva.pdf (Pág 17)	Domini no oficial (aeats.eu); sense https; demana targeta i CVV per a una devolució	Manipulació del DNS que porta a una web falsa amb l’aspecte de l’oficial	Revisar el domini i el https; no donar mai dades de la targeta; usar un DNS fiable

Angler phishing	 https://www.proofpoint.com/es/threat-insight/post/fraudulent-social-media-accounts-continue-phish-banking-credentials	Compte de suport no oficial (@AskPayPal_Tech) amb molt pocs tuits i creat fa poc; respon a clients amb un enllaç bit.ly; demana re-verificar el compte	Perfil fals a xarxes socials amb assistència enganyosa	Contactar només pels canals oficials del web; no clicar enllaços escurçats; verificar que el compte té el segell oficial
Search engine phishing	 https://www.eftsure.com/finance-glossary/search-engine-phishing/	Domini diferent de l'oficial (banklogin.open.org); falta al nom ("Amercia"); apareix entre els resultats oficials	Resultat de cerca manipulat que duu a una web falsa	Guardar la web del banc als preferits; revisar el domini abans d'entrar

Phishing correu

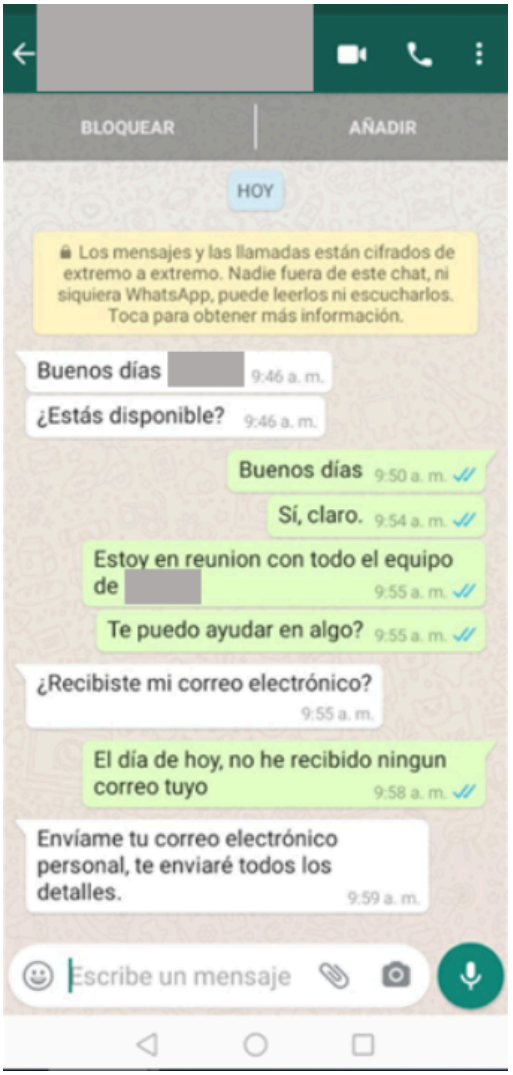


Spear phishing



Whaling





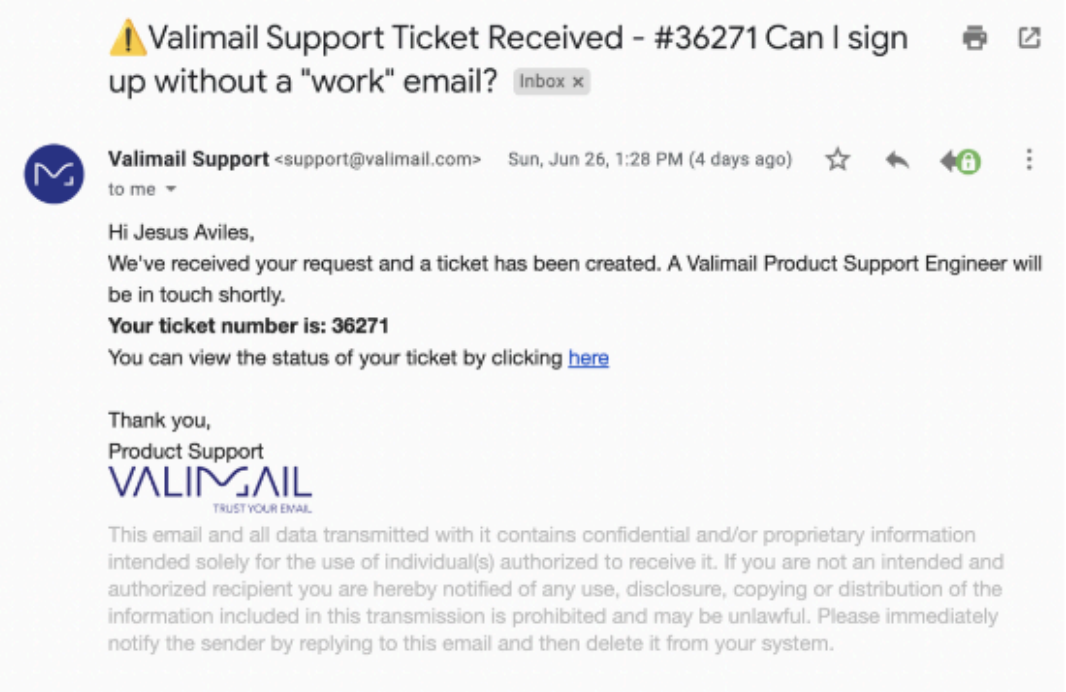
Smishing



Vishing



Clone phishing



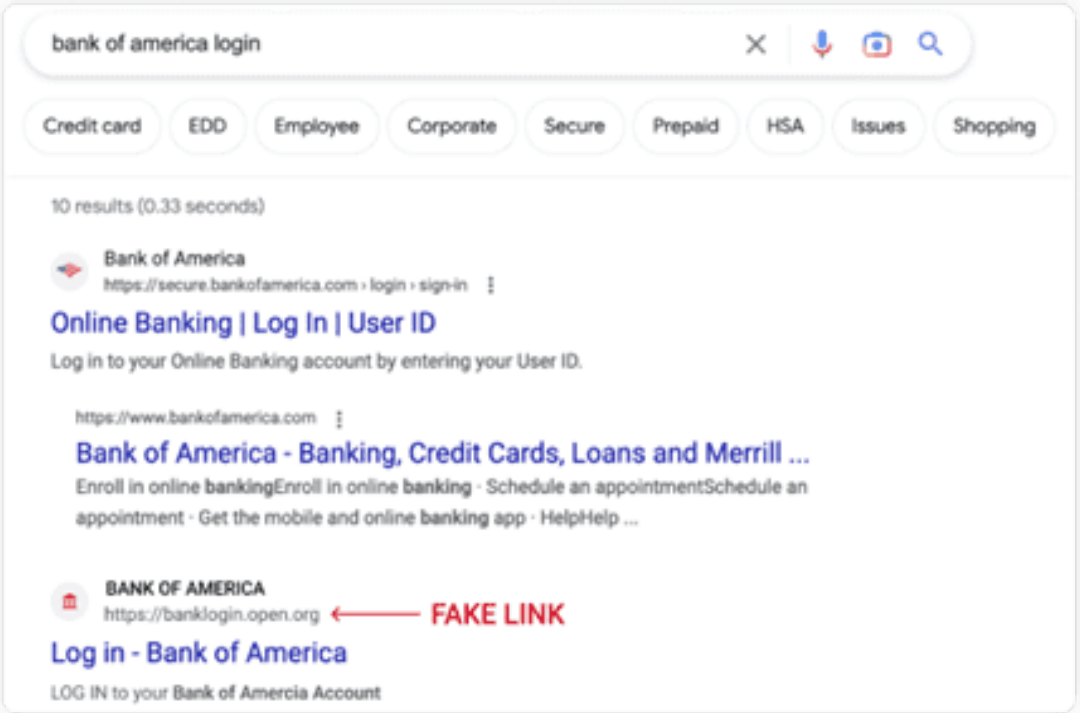
Pharming



Angler phishing



Search engine phishing



2. Escenari Fictici

Context de l'empresa
Linares Solutions és una petita empresa dedicada a la venda en línia, amb una oficina de pocs ordinadors, una xarxa wifi i connexió a internet. La informació s'hi fa servir per contactar amb clients i proveïdors, mantenir la botiga online, elaborar factures i intercanviar dades amb la gestoria, que s'encarrega dels recursos humans i dels impostos. L'empresa té contractats els serveis d'una gestoria i de suport informàtic extern. Els empleats treballen en horari comercial, i els clients contacten per telèfon, per correu electrònic o presencialment.

Què ha succeït?
En tornar de vacances, a Linares Solutions es van revisar els extractes bancaris de l'última setmana i es van detectar càrrecs que ningú havia autoritzat. Les ordres de pagament s'havien fet fora de l'horari comercial, i el banc va confirmar que s'havien fet correctament amb les credencials de facturació de l'empresa. Un empleat va explicar que havia enviat aquestes credencials per correu perquè el cap les hi havia demanat, dient que estava de vacances i necessitava fer una transacció urgent. En realitat el missatge no era del cap: l'adreça del remitent era falsa i l'empleat no s'hi va fixar. Es tracta d'un cas de spear phishing, conegut com a frau del CEO, que es basa en la suplantació d'una figura d'autoritat i en la pressa.

Què hem de fer?
Primer, cal avisar el banc immediatament per bloquejar el compte i reclamar els càrrecs, ja que com abans es faci, més possibilitats hi ha de recuperar els diners. Tot seguit s'han de canviar totes les contrasenyes exposades i activar l'autenticació de dos factors. També convé denunciar els fets als Mossos d'Esquadra o a la Policia i guardar totes les proves: el correu fals amb les seves capçaleres, els extractes bancaris i els registres d'accés. Després, s'han de revisar els equips amb un antivirus per descartar programari maliciós i avisar la gestoria, els clients i els proveïdors. Si hi ha dades personals afectades, a més, cal notificar l'incident a l'Agència Espanyola de Protecció de Dades.

Què no hem de fer?
No s'han d'enviar mai credencials per correu, encara que sembli que les demana el cap, ni actuar davant una petició sensible sense verificar-la per un altre canal, com una trucada. Tampoc s'ha d'amagar l'incident ni culpar l'empleat, perquè això faria que en el futur algú tingués por d'avisar d'un error. No s'ha d'esborrar el correu ni cap prova, i no s'han de reutilitzar les contrasenyes antigues. Finalment, no s'ha d'esperar, perquè cada hora compta per aturar els pagaments i recuperar els diners.

Què hem après? Com evitar-ho?
Hem après que els atacants s'aprofiten de la confiança, de l'autoritat i de la urgència, i que una petició que sembla venir del cap no és de fiar només pel nom del remitent. Per evitar-ho, cal verificar sempre les peticions sensibles amb una trucada, mirar l'adreça real del remitent i establir una norma clara: les credencials no es demanen mai per correu. També és útil activar l'autenticació de dos factors i exigir una doble aprovació en els pagaments. Finalment, l'empresa ha de fer formació periòdica en ciberseguretat, tenir un protocol d'incidents i oferir un canal perquè els empleats puguin reportar correus sospitosos sense por.